Cyber Security Foundations | CySec

Summary

CONTENTS

1. Information security . . . 3
1.1. Types of information . . . 3
1.2. How can information be attacked . . . 4
1.3. Components of an Information System (IS) . . . 4
1.4. Balancing security and system usability . . . 4
1.5. Implementation of information security . . . 4
1.6. CIA Triad . . . 5
1.7. Non-Repudiation and Accountability . . . 5
1.7.1. Non-Repudiation . . . 5
1.7.2. Accountability . . . 5
1.8. STRIDE Model . . . 5
1.9. McCumber Cube . . . 6

2. Threat categorization . . . 6
2.1. Social engineering . . . 6
2.2. Software attacks . . . 6
2.3. Denial of service . . . 7
2.4. Web application attacks . . . 7
2.5. Password / Authentication attacks . . . 7
2.6. Physical threats . . . 8

3. Information Security Management . . . 8
3.1. Information Security Governance . . . 8
3.2. Information Security Management System (ISMS) . . . 9

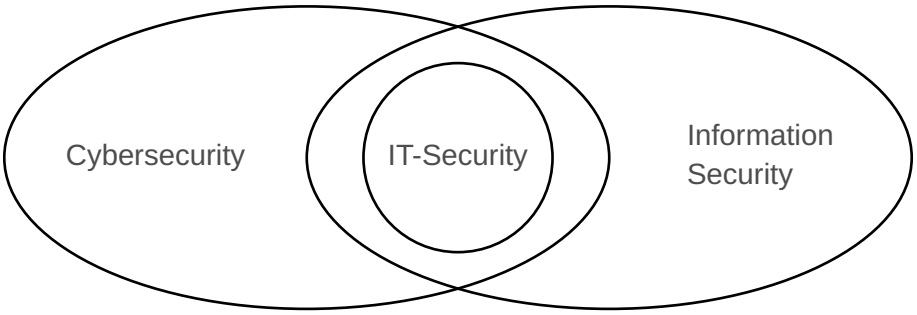
4. Policy . . . 9
4.1. Designing effective policies . . . 10
4.2. Enterprise Information Security Policy (EISP) . . . 11
4.2.1. Elements of an EISP . . . 11
4.3. Issue-Specific Security Policy . . . 11

5. Risk analysis . . . 11
5.1. Identifying Assets . . . 12
5.2. Classifying Assets . . . 12
5.3. Identifying Threats . . . 12
5.4. Security Controls . . . 12
5.4.1. Types . . . 12
5.4.2. By Function . . . 13
5.5. Business Continuity Management . . . 13
5.5.1. Key Objectives . . . 13
5.6. Security and Awareness Training . . . 13
5.7. Gap Analysis . . . 14
5.8. Security Framework . . . 14
5.9. ISO/IEC 2700 . . . 14
5.10. NIST Cybersecurity Framework . . . 14

5.11. Risk, Vulnerabilities and Threats . . . 14
5.11.1. Vulnerabilities . . . 14
5.11.2. Threat . . . 15
5.11.3. Threat actors . . . 15
5.11.4. Threat Vector . . . 15
5.11.5. Attack surface . . . 15
5.11.6. Risk . . . 15
5.12. Risk Management . . . 15
5.12.1. RM Framework . . . 16
5.12.2. Risk Management Process . . . 16
5.12.3. Risk Identification . . . 16
5.12.4. CVE & CVSS . . . 17
5.12.5. Risk Analysis . . . 17
5.12.6. Quantitative Risk Analysis . . . 17
5.12.7. Risk Evaluation . . . 19
5.12.8. Risk Treatment . . . 19
5.12.9. Other RM Frameworks . . . 19

1. INFORMATION SECURITY

Term	*Definition*
Information	An organization's data that has been processed, organized, or structured in a way that gives it meaning and value to an organization or individual.
Information security	Protection of the integrity, confidentiality and availability of information data whether in storage, transit or processing.
non-repudiation	prevents parties from denying actions they have performed.
accountability	ability to trace actions and decisions back to a specific person or system.
authentication	verifies the identity of a user or system.
authorization	determines what actions an authenticated entity is allowed to perform.
access control	restricts access to resources based on defined rules.
business continuity	ensures critical operations continue during disruptions.
security policy	a rule or expectation for protecting information.
compliance	adherence to laws, regulations, and (security-)standards.
asset	any item of value belonging to an organization – For example: information, systems, people and processes
attack	an act that intends to damage, steal or degrade an organizations assets
vulnerability	a flaw or weakness in a system that can be abused
exploit	a technique or method used to take advantage of a vulnerability
threat	an event or action with the potential to cause harm by exploiting a vulnerability
risk	the likelihood of a threat exploiting a vulnerability and the potential harm that could cause
control	a measure designed to reduce the potential risk of an attack – Can be achieved through training employees, enforcing policies or implementing technology



1.1. TYPES OF INFORMATION

- Personal information
- Business information
- Financial information
- Intellectual property
  - Copyright
  - Trademarks
  - Patents
  - Trade secrets

- System information

1.2. HOW CAN INFORMATION BE ATTACKED

- In storage
  - Data that is stored on a server or in a database short-term or long-term.
- In transit
  - Data that is currently being transported from one place to another.
- In use
  - Data that is currently being processed by a service or another entity.

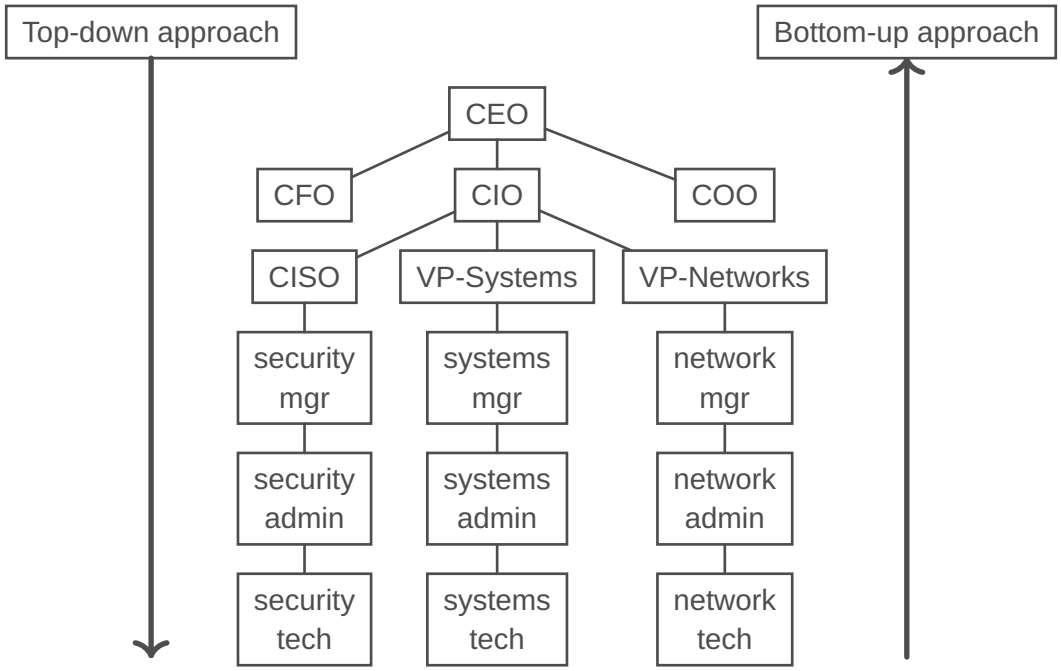
1.3. COMPONENTS OF AN INFORMATION SYSTEM (IS)

- Software
- Hardware
- Data
- People
- Procedures
- Networks

1.4. BALANCING SECURITY AND SYSTEM USABILITY

- Obtaining perfect information security is impossible.
- Security needs to protect the system without slowing people down.
- Too much security can lead to workarounds.
  - Example: If strong passwords are enforced, people might start writing them down on sticky notes.
- Too much convenience exposes the system to unnecessary risks.
- It's all about finding that sweet spot between security and usability.
  - Example Solution: Employees must use multi-factor authentication. This way, they are free to use a less secure password without compromising the overall security.
- An even better, continuously review policies and involve users to find the best solution.

1.5. IMPLEMENTATION OF INFORMATION SECURITY



Bottom-Up | ***Top-Down***

– Initiated by an organization's technical staff (system engineers, admins, etc.). – Implementations happen before policies are defined. – Often lacks support from management, budget and consistency. – Generally less effective and not scalable in large organizations.	– Initiated and supported by an organization's upper management. – Policies come first and provide guidance for implementations. – Ensures proper funding, authority and organization-wide enforcement. – Generally more effective and in-line with the business strategy

1.6. CIA TRIAD

The CIA triad is a foundational information-security model stating that systems should protect:

– **Confidentiality** - Keeping information secret
– **Integrity** - Keeping information correct and unaltered
– **Availability** - Ensuring information and systems remain accessible

	Confidentiality	***Integrity***	***Availability***
Goal	Prevent or minimize unauthorized access to information	Protecting the reliability and correctness of information.	Ensuring that subjects have timely and uninterrupted access to information.
Steps to ensure it	– Encryption – Access Control – Allow / enforce advanced authentication mechanisms	– Digital Signatures – Hashing and Checksums – Change Management	– Redundance and Backups – DDoS Protection – Incident Response

1.7. NON-REPUDIATION AND ACCOUNTABILITY

Example of security controls through which non-repudiation can be established: Digital certificates, session identifiers, transaction logs, etc.

1.7.1. Non-Repudiation

– Ensures that the subject of an activity or who caused an event cannot deny having performed an action or cannot deny that the event occurred.
– Non-Repudiation prevents a subject from claiming not to have sent a message, not to have performed an action, or not to have been the cause of an event.

1.7.2. Accountability

– Being responsible or obligated for actions and results.
– Non-Repudiation is an essential part of accountability. A suspect cannot be held accountable if they can repudiate the claim against them.

1.8. STRIDE MODEL

A structured model developed by Microsoft used in cybersecurity to identify and categorize threats to systems by looking at how they can be attacked.

TODO:
Authenticity

Term	***Definition***
S(poofing)	Pretending to be someone else. (see Authenticity)
T(ampering)	Unauthorized data modification or altering. (see Integrity)

Term	Definition
R(epudiation)	Denying actions without proof. (see Non-Repudiation)
I(nformation disclosure)	Exposing sensitive information. (see Confidentiality)
D(enial of service)	Making systems or services unavailable. (see Availability)
E(levation of privilege)	Gaining unauthorized rights or privileges. (see Authorization)

1.9. MCCUMBER CUBE

Y-Axis: Security Goals (C.I.A. Triad)

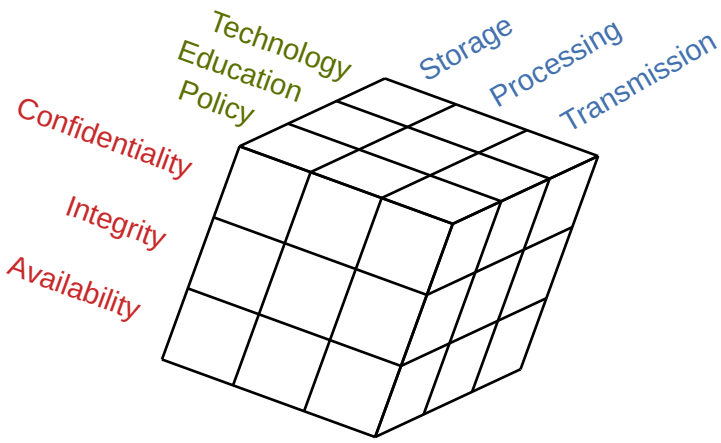
– Defines what needs to be protected.

X-Axis: Information States

– Describes where the information exists.

Z-Axis: Safeguards / Controls

– Defines how protection is implemented.



2. THREAT CATEGORIZATION

Term	Definition
Social Engineering	Manipulating people to reveal confidential information.
Software Attacks	Exploiting vulnerabilities in software to gain access to a system or steal data.
Denial of Service	Overloading one or multiple systems to make it unavailable.
Web Application Attacks	Exploiting vulnerabilities in websites or servers hosting websites.
Password / Authentication Attacks	Attempting to bypass or compromise login systems to gain unauthorized access.
Physical Attacks	Bypassing technical controls by accessing physical infrastructure directly.

2.1. SOCIAL ENGINEERING

The psychological manipulation of individuals to trick them into revealing confidential information or performing actions that can compromise security.

Term	Definition
Phishing	Forged emails impersonating legitimate entities.
Spear Phishing	Targeted phishing against specific individuals.
Vishing	Voice-based phishing over phone or video calls.
Smishing	SMS / Text-based phishing.

2.2. SOFTWARE ATTACKS

Attacks involving malicious code or malware designed to damage systems, steal sensitive data, or gain unauthorized access to systems or services.

Term	Definition
Virus	Malware that attaches to programs and spreads.

Term	*Definition*
Worms	Self-replicating malware that spreads over a network.
Trojan Horse	Malicious software disguised as legitimate applications.
Ransomware	Malware that encrypts victim's data and demands payment to restore access.
Rootkits	Stealthy tools that hide malicious activity and maintain privileged access.

2.3. DENIAL OF SERVICE

Attacks aims at making a system or service unavailable by overwhelming it with excessive traffic or requests.

Term	*Definition*
DoS	Single source denial of service attacks.
DDoS	Denial-of-service attacks performed by multiple attackers or attacking devices.
Botnet	A network of compromised computers and other devices controlled by an attacker and used to together to flood a target with excessive traffic.
SYN-Flood Attack	Sending many connection requests without completing them.
Reflection Attack	Attacker sends requests to a service and spoofs the victim's IP making the service send (many) replies to the victim instead of back to the attacker.

2.4. WEB APPLICATION ATTACKS

Exploits vulnerabilities in web applications to steal data, manipulate content, or gain unauthorized access.

Term	*Definition*
SQL Injection	An attacker inserts malicious SQL commands into an input to manipulate a database and access, modify, or delete data.
Cross-Site Scripting (XSS)	An attacker injects malicious scripts into a website that execute in other users' browsers to steal sensitive data.
Cross-Site Request Forgery (CSRF)	An attacker tricks a logged-in user's browser into sending unauthorized requests to a web application on their behalf.
Broken Authentication	Weak authentication mechanisms allow attackers to compromise passwords, sessions, or identities to gain unauthorized access.

2.5. PASSWORD / AUTHENTICATION ATTACKS

Attacks that attempt to bypass or compromise login systems to gain unauthorized access to a system or service.

Term	*Definition*
Rainbow Table Attacks	Attackers using precomputed hash lookup tables to reverse weakly hashed passwords back into plaintext.
Password Spraying	Attackers trying a few common password like "password" across many accounts to avoid lockouts or timeouts.
Credential Stuffing	Attackers using leaked usernames and passwords from previous breaches to attempt logins on other services.
Brute Force Attack	Attackers repeatedly try many username and password combinations until they successfully gain access to an account.

2.6. PHYSICAL THREATS

Threats or attacks that affect the physical infrastructure supporting information systems, usually bypassing technical controls overall.

Term	*Definition*
Theft of devices	Attackers physically steal hardware to gain direct access to stored data, credential, internal systems, or other sensitive data.
Hardware tampering	An attacker modifies or implants malicious components in physical equipment to intercept data, bypass security, or disrupt operations.
Power disruption	Attackers interrupt or manipulate power supply to shut down or destabilize critical systems or services impacting availability and business continuity.
Environmental damage	Natural or deliberate environmental events that damage infrastructure, causing data loss, downtime, or destruction of critical systems (e.g., earthquake, fire).

3. INFORMATION SECURITY MANAGEMENT

3.1. INFORMATION SECURITY GOVERNANCE

The system by which an organization directs and controls its information security strategy to ensure that it supports business objectives, manages risk appropriately, and complies with legal and other regulatory requirements.

Strategic Direction

– Defining security objectives aligned with business goals.

Leadership and Accountability

– Having clear roles and responsibilities for security decisions.

Risk Management

– Defining risks and ensuring they are identified and addressed appropriately.

Regulatory Compliance

– Ensuring adherence to laws and regulations (e.g. NIS2, HIPAA, CRA)

Responsibilities	*Functional Role Examples*
– Oversee overall corporate security posture (accountable to board) – Brief board, customers, public	– Chief Executive Officer
– Set security policy, procedures, program, training for company – Respond to security breaches (investigate, mitigate, litigate) – Responsible for independent annual audit coordination	– Chief Security Officer – Chief Information Officer – Chief Risk Officer – Department/Agency Head
– Implement/audit/enforce/assess compliance – Communicate policies, program (training)	– Mid-Level Manager
– Implement policy; report security vulnerabilities and breaches	– Enterprise Staff/Employees

3.2. INFORMATION SECURITY MANAGEMENT SYSTEM (ISMS)

A structured framework used to systematically manage and protect an organization's assets through various policies, processes and controls

Security governance defines **what** an organization wants to achieve. An ISMS defines **how** the organization wants to manage it.

Enterprise Information Security Policy (EISP)

– The information security policy that sets the strategic direction and scope for all an organization's security efforts.

Risk Management Process
– Definition of processes to identify assets, analyze threats and evaluate risk.

Security Awareness and Training
– Educational programs to ensure employees understand their security responsibilities.

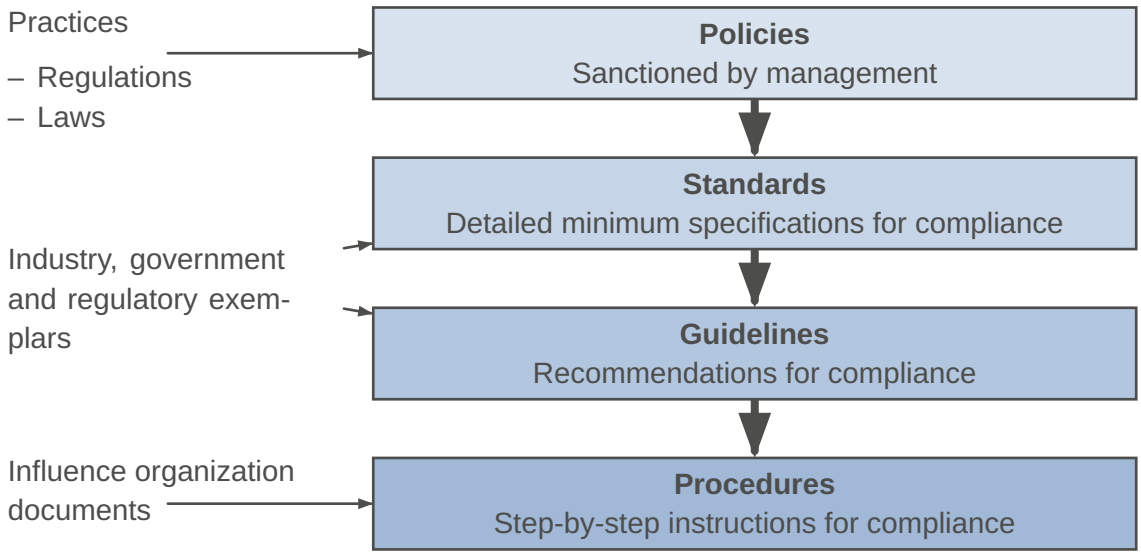
Monitoring, Measurement and Audits
– Ongoing evaluation of control effectiveness and ISMS performance.

4. POLICY

A high-level, management-approved rule that defines mandatory organizational behavior and translates external laws and regulations into enforceable internal requirements.

Term	*Definition*
policy	instructions that dictate certain behavior within an organization.

Term	***Definition***
guidelines	non-mandatory recommendations employees may use as a reference.
procedures	step-by-step instructions designed to assist employees in following policies.
practices	examples of actions that illustrate compliance with policies.
standard	a detailed statement of what must be done to comply with a policy.
de jure standard	a standard that has been formally evaluated and approved by a formal standards organization
de facto standard	a standard that is widely adopted or accepted by a public group.



What does a policy do? Establishes authority, accountability, and responsibilities for protecting information assets. Provides the foundation for standards, procedures and guidelines.

Who is responsible for policies? Policies are created and approved by senior management, ensuring organizational commitment. Management is responsible for enforcement while employees and users are responsible for compliance.

How is a policy enforced? By clearly communicating it to all relevant parties, integrating it into standards and procedures, monitoring compliance through audits and oversight, and applying defined disciplinary measures when violations occur.

- Cyber Resilience Act (EU)
  - Requires secure-by-design digital products and vulnerability management (starting December 2027).
- Health Insurance Portability and Accountability Act (U.S.)
  - Requires administrative, technical, and physical safeguards for protecting patient health data from disclosure.
- NIS2 Directive (EU)
  - Mandates cybersecurity risk management and incident reporting for critical and important entities.
- Local Laws
  - Many regions have their own data protection or breach notification laws in additional to national or EU regulations.

4.1. DESIGNING EFFECTIVE POLICIES

1) Development
   - Policies must align with organizational goals, business risks and legal requirements.
2) Distribution
   - Policies must be distributed to all affected entities in a timely manner.

3) Comprehension
   – Policies must be readable for, available to and read by all affected entities.
4) Compliance
   – Policies must be formally agreed to by act or affirmation.
5) Enforcement
   – Policies must be uniformly applied to all affected entities.
6) Review
   – Policies must be reviewed regularly in a changing environment.

4.2. ENTERPRISE INFORMATION SECURITY POLICY (EISP)

The high-level information security policy that sets the strategic direction, scope and tone for all an organization's security efforts and policies.

– Guidance for the development, implementation and management of the security program.
– Sets the requirements that must be met by the information security blueprint.
– Defines the purpose, scope, constraints and applicability of the security program.
– Assigns responsibilities for the various areas of information security.
– Addresses legal compliance.

4.2.1. Elements of an EISP

Although the content of EISP documents varies among organizations, most EISP documents should include the following elements.

– Statement of Purpose
  – Statement of intent that defines the scope, objectives, and purpose of the enterprise information security policy and establishes its role as the foundation for all supporting security documents.
– Information Security Elements
  – Definition of information security that outlines the core principles and concepts, including confidentiality, integrity, and availability, guiding the organization's security efforts.
– Need for Information Security
  – Definition of the importance of information security within an organization and its legal and ethical responsibility to protect information about customers, employees, and markets.
– Information Security Responsibilities and Roles
  – Description of the organizational structure that supports information security, including defined roles and responsibilities for management, employees, and users, as well as responsibility for maintaining the policy itself.

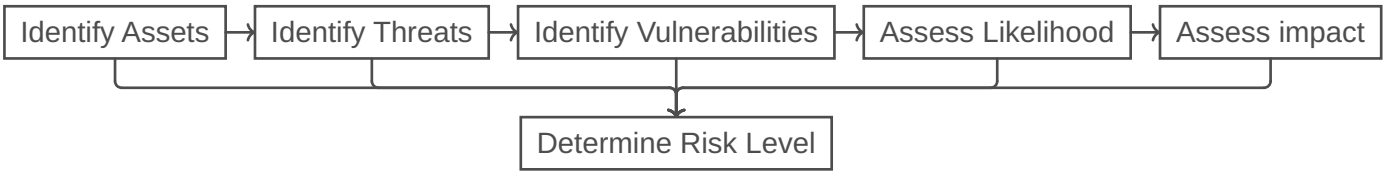
4.3. ISSUE-SPECIFIC SECURITY POLICY

An organizational policy that provides detailed, targeted guidance to instruct members of an organization in the use of a specific resource.

– Supports the EISP by translating it into an issue-specific guidance.
– Establishes rules for access, monitoring, and protection of the resource.
– Defines acceptable and unacceptable use of the specified technology or resource.
– Assigns responsibilities and accountability to users, administrators, and management.

5. RISK ANALYSIS

The process of identifying assets, threats, and vulnerabilities, and evaluating the likelihood and impact of potential adverse events to determine the level of risk.



5.1. IDENTIFYING ASSETS

Term	*Definition*
Asset	Any resource that has some kind of value to an organization and therefore requires protection.
Information Assets	Customer data, intellectual property, source code, etc.
Technical Assets	Services, applications, databases, networks, etc.
Physical Assets	Servers, devices, facilities, infrastructure, etc.
Human Assets	Employees, administrators, contractors, key personnel, etc.
Business Process Assets	Critical operational workflows

5.2. CLASSIFYING ASSETS

The process of assigning every asset to a class based on their value, sensitivity and impact if compromised

Term	*Definition*
Public	Information that can be shared without risk
Internal	Information for organization internal use only
Confidential	Sensitive information that could cause harm if disclosed
Restricted	Highly sensitive, strictly limited and strongly protected information

5.3. IDENTIFYING THREATS

A potential event, actor, or action that could exploit a vulnerability and cause harm to an asset.

Examples: Power outage, insider threat, vishing attack

5.4. SECURITY CONTROLS

TODO:
belongs into information security management

Measures to reduce risk by detecting, preventing, responding to, or mitigating threats to organizational assets.

5.4.1. Types

Term	*Definition*
Administrative / Management Controls	Policies, procedures, security training, security governance, etc.
Technical / Logical Controls	Firewalls, encryption, access control systems, system hardening, etc.
Physical Controls	Physical locks, surveillance cameras, secure access badges, turnstiles, etc.

5.4.2. By Function

Term	*Definition*
Preventive Controls	Stop incidents before they occur. e.g., Firewalls, access control, encryption, etc.
Detective Controls	Identify incidents when they occur. e.g., Intrusion detection, log monitoring, SIEM, CCTV, etc.
Corrective Controls	Limit damage and restore systems after an incident. e.g., Backups, system restore, incident response, etc.
Deterrent Controls	Discourage malicious behavior. e.g., Warning banners, monitoring notices, disciplinary policies, etc.
Compensating Controls	Reduce risk when a primary control cannot be implemented. e.g., Network isolation, layered security, alternative safeguards, etc.

5.5. BUSINESS CONTINUITY MANAGEMENT

Ensures that critical business functions can continue during and after incidents or disruptions such as cyberattacks, system failures, or physical incidents.

Even with strong security controls in place, incidents can and will still occur at some point. BCM prepares the organization to operate and recover during these times.

5.5.1. Key Objectives

- Maintain critical operations during incidents.
  e.g., backups, redundant services, manual processing, etc.
- Minimize downtime and financial impact.
  e.g., fast system restore, emergency support contracts, incident response team, etc.
- Protect people, assets and reputation
  e.g., evacuation plans, fire suppression systems, customer notification processes, etc.
- Enable fast and structured recovery
  e.g., disaster recovery playbooks, tested backup restoration, post-incident review processes, etc.

5.6. SECURITY AND AWARENESS TRAINING

A coordinated program designed to ensure that all members of an organization understand their security responsibilities and have the knowledge and skills to protect information assets.

	Awareness (Level 1)	*Training (Level 2)*	*Education (Level 3)*
Objective	Seeks to teach members of an organization **what** security is and what to do in certain situations	Seeks to train members of an organization **how** they should react and respond to certain situations	Seeks to educate members of an organization as to **why** the organization reacts the way it does
Complexity Level	Offers **basic information** about threats and responses	Offers more **detailed knowledge** about detecting threats and teaches skills needed for effective reaction	Offers the background and **depth of knowledge** to gain insight into how processes are developed and enables ongoing improvement
Teaching Method	– Videos – Newsletters – Posters – Informal Training	– Informal Training – Workshops – Hands-on Practice	– Theoretical Instruction – Discussions / Seminars – Background Reading

Impact timeframe	Short-term	Intermediate	Long-term

5.7. GAP ANALYSIS

The process of comparing an organization's current security posture with a required or desired target to identify missing or insufficient controls.

- Risk Analysis: What could go wrong?
- Gap Analysis: Where are we non-compliant or under-protected?

Define a target framework → Assess the current state → Identify gaps and assess risk → Evaluate and prioritize gaps → Develop a remediation plan

5.8. SECURITY FRAMEWORK

A structured set of principles, processes, and controls that organizations use to manage risks and protect their information systems, assets, and operations.

Framework	***Definition***
ISO/IEC 27000	Global standard for information security management systems (ISMS).
NIST Cybersecurity Framework	Practical framework for managing cyber risk
CIS Controls	Defines 18 highly practical technical security controls
ISACA CORBIT	An IT governance and risk management framework.

5.9. ISO/IEC 2700

A set of standards for ISMS, helping organizations systematically protect information assets using a risk-based approach.

Standart	***Definition***
ISO/IEC 27000	Introduction, terminology, and key concepts (e.g., risk, asset, control, etc.)
ISO/IEC 27001	Defines requirements to establish, implement, maintain, and improve an ISMS.
ISO/IEC 27002	Practical guidance for implementing controls.
ISO/IEC 27005	Focuses on risk management methodology.
ISO/IEC 27017	Additional guidance for cloud services.
ISO/IEC 27018	Focuses on privacy and personal data protection in cloud environments.

5.10. NIST CYBERSECURITY FRAMEWORK

A risk-based guideline that helps organizations to structure, manage, and improve their cybersecurity activities across the full lifecycle of prevention, detection, and response.

- It's organized into five core functions; Identify, Protect, Detect, Respond, Recover.
- Provides categories and subcategories of cybersecurity outcomes and controls.
- Includes implementation tiers to assess cybersecurity maturity.
- Is very flexible and adaptable to any organization or business sector.
- Not certifiable, primarily used as guidance and best practice.

5.11. RISK, VULNERABILITIES AND THREATS

5.11.1. Vulnerabilities

A potential weakness in an asset or its defensive control system. Can be **known** or **unknown**.

Examples:

- Software vulnerabilities (Bugs, design flaws, …).
- Human vulnerabilities (sharing passwords, …).

5.11.2. Threat

A potential malicious action, or event that aims to damage, or steal unauthorized access to assets. A threat exploits system vulnerabilities.

- Threat: What?
- Threat Actor: Who?
- Threat Vector: How?

5.11.3. Threat actors

Motivations	***Actor Types***

– Service disruptions
– Data exfiltration
– Disinformation
– Chaotic / Vandalism
– Financial
  – Blackmailing
  – Fraud
– Political
	– Hackers
	– Unskilled Attackers & Script Kiddies
	– Hacker Teams & Hacktivists
	– Nation-State Actors
	– Organized Crime
	– Internal Threat Actors

5.11.4. Threat Vector

The path, method, or delivery mechanism that a threat uses to reach an asset and exploit a vulnerability.

Types:
- Software Vectors (Bugs, Virus, …)
- Network Vectors (Bluetooth, Open Ports, Remote Network, …)
- Lure-Based Vectors (Drop Attacks with USB Sticks, Trojans, …)
- Message-Based Vectors (SMS, Email, IM, Web and Social Media, …)
- Supply Chain Vectors (Updates, Libraries, …)

5.11.5. Attack surface

The sum of vulnerabilities, pathways, or methods (Threat vectors) that hackers can use to gain unauthorized access to the network or sensitive data, or to carry out a cyberattack.

5.11.6. Risk

The probability of an unwanted occurrence, such as an undesirable event or loss.

- The definition of risk implies threats and vulnerabilities: A risk is only here if we have an existing vulnerability, threat, and threat vector!
- Risk = Vulnerability (Value & Exposure) + Threat (Threat Actor & Threat vector)

At what cost are we willing to accept what risk? The answer to that question gives us risk management.

5.12. RISK MANAGEMENT

The process of identifying, assessing, prioritizing and mitigating threats to an asset from an organisation.

Risk management framework: Structure of the strategic planning and design of the entirety of the risk management efforts (planning).

Risk management process: implementation, analysis, evaluation of the risk management framework (doing).

TODO:
slides 17

5.12.1. RM Framework

1) ***Executive Governance & Support***: Support from management and users.
2) ***Framework Design***: Defining the methods and risk appetite strategy.
3) ***Framework Implementation***: Rollout of the plan (through →RM process).
4) ***Monitoring & Review***: How effective is the entire system?
5) ***Continuous Improvement***: Continuous adaption to new , or existing threats.

5.12.1.1. Executive Governance and Support

TODO:
slides 19

5.12.1.2. Framework Design

Defining the methods and risk appetite strategy

Term	***Definition***
Risk appetite (strategic)	The quantity of risk that organizations are willing to accept, to achieve their goals.
Risk tolerance (specific)	The acceptable risk organizations are willing to accept for a specific asset.
Residual risk	The risk that still remains after all controls have been applied.

5.12.1.3. Framework Implementation

Framework Implementation starts after:

- The RM framework and process is finished designing.
- The structure of the RM process & framework is defined.

The methodologies are dependent on the risk appetite:

- Direct rollout
- Pilot-test
- Phased approach

5.12.1.4. Monitoring & Review

- How successful was the framework in the last cycle?
  - Designing
  - Implementing
- What issues require adjustments to the plan?

5.12.2. Risk Management Process

Risk assessment: The identification, analysis, and evaluation of risk as initial parts of risk management.

Risk treatment & Risk Owner: The application of safeguards or controls to reduce the risks to an organization's information assets to an acceptable level.

1) **Risk identification**: Where and what is the risk?
2) **Risk analysis**: How severe is the current level of risk?
3) **Risk evaluation**: Is the current level of risk acceptable?
4) **Risk treatment**: What do I need to do to bring the risk to an acceptable level?

5.12.3. Risk Identification

The recognition, enumeration, and documentation of risks to an organization's information assets.

Where and what is the risk?

- What are the assets of the organisation? (Internal Asset Register, Weighted Asset Table)
  - Data, Software, Hardware, Networks, Employees, procedures, …
- What are the threats of the organisation? (ATT&CK is a globally-accessible knowledge base).
  - Human error, Attacks from hackers, forces of nature, day zero attacks …
- What are the vulnerabilities? (CVE and CVSS helps with that question).
  - Lack of training, known bugs in the system, day zero exploit
- Precision is key: If THIS then THAT, because OF …

5.12.4. CVE & CVSS

- A Common Vulnerabilities and Exposures (CVE) is an industry-wide standard identification number for vulnerabilities.
- The Common Vulnerability Scoring System (CVSS) uses the CIA triad principles within the metrics used to calculate the CVVS base score and assigns severity scores to a vulnerability

5.12.5. Risk Analysis

A determination of the extent to which an organization's information assets are exposed to risk.

Identify the severity of every identified threat and vulnerability.

- What is the probability of an attack?
- What would be the impact of an attack?
  - Quantitative risk analysis assigns real dollar figures to the loss of an asset.
  - Qualitative risk analysis assigns subjective and intangible values to the loss of an asset.
- Existing Security Controls shall be considered

5.12.6. Quantitative Risk Analysis

1) Assign Asset Value (AV)
2) Calculate Exposure Factor (EF)
3) Calculate single loss expectancy (SLE)
4) Assess the annualized rate of occurrence (ARO)
5) Derive the annualized loss expectancy (ALE)
6) Perform cost/benfit analysis of countermeasures

5.12.6.1. AV

1) Identify the organization's information assets.
2) Classify them.
3) Categorize them into useful groups.
4) Prioritize them by overall importance.

***Example 1* : Weighted Asset Table**

		Impact on Revenue	*Impact on Profitability*	*Impact on Reputation*		
#		**0.3**	**0.4**	**0.3**	**TOTAL (1.0)**	**Importance**
1	Customer order via SSL	5	5	5	5	Critically Important

2	Customer service request via e-mail	3	3	5	3.6	Important
⋮	⋮	⋮	⋮	⋮	⋮	⋮

5.12.6.2. EF, SLE

- ***Exposure factor (EF)***: Represents the percentage of loss that an organization would experience if a specific asset is violated by a realized risk.
  - In most cases, a realized risk does not result in the total loss of an asset. The EF simply indicates the expect.
- ***Single loss expectancy (SLE)***: The cost associated with a single realized risk against a specific asset. It indicates the exact amount of loss an organization would experience if an asset were harmed by a specific threat occurring.
  - SLE = asset value (AV) × exposure factor (EF)
  - Example: if an asset is valued at $200,000 and it has an EF of 45 % for a specific threat, then the SLE of the threat for that asset is $90,000.

5.12.6.3. ARO, ALE

- ***Annualized rate of occurrence (ARO)***: The expected frequency with which a specific threat or risk will occur within a single year.
  - Example: The ARO of an earthquake in Paris may be .00001, whereas the ARO of an earthquake in San Francisco may be .03 (for a 6.7+ magnitude).
- ***Annualized loss expectancy (ALE)***: The possible yearly cost of all instances of a specific realized threat against a specific asset.
  - ALE = single loss expectancy (SLE) ·annualized rate of occurrence (ARO)
  - If the SLE of an asset is $90,000 and the ARO for a specific threat (such as total power loss) is .5, then the ALE is $45,000.
    On the other hand, if the ARO for a specific threat (such as compromised user account) is 15, then the ALE would be $1,350,00

5.12.6.4. ALE with Safeguards

- You must calculate the ALE for the asset if the safeguard is implemented.
  - This requires a new EF and ARO specific to the safeguard.
  - The whole point of a safeguard is to reduce the ARO and/or reduce the SLE. The best of all possible safeguards would reduce the ARO to zero.
  - In most cases, the EF to an asset remains the same even with an applied safeguard because if the safeguard fails, the loss on the asset is usually the same as when there is no safeguard.
- Safeguard Costs
  - You must first compile a list of safeguards for each threat. Then you assign each safeguard a deployment value = ACS (Annual cost of the safeguard).

5.12.6.5. Value of a Safeguard

Net Value or Cost/Benefit of a safeguard:

- Negative value: not a responsible choice.
- Positive value: Then the value represents the yearly savings in cost that you CAN have (because the rate of occurrence is just an expected value).

Safety needs to be cost effective. Do not use more resources or money for the protection of an asset as the value of the asset itself!

5.12.7. Risk Evaluation

The process of comparing an information asset's risk rating to the numerical representation of the organization's risk appetite or risk threshold to determine if risk treatment is required.

Risk Evaluation: Compare the risk with the risk appetite of the organization.

- Can the company live with the analysed level of risk (From the CVSS, the quantitative risk analysis, qualitative risk analysis)?
- Levels: Expansionary, Conservative or Neutral

The Risk appetite from the RM Framework must be translated into a value so it can be compared to each analysed risk.

- For the quantitative risk analysis, the risk appetite can be translated into a numerical value!

Goal: The risk must be smaller or equal as the risk appetite.

- Important Indicators for Business Impact:
  - Maximum Tolerable Downtime (MTD)
  - Recovery Point Objective (RPO)
  - Recovery Time Objective (RTO) & Work Recovery Time (WRT)

5.12.8. Risk Treatment

Mitigation risk treatment strategy: The risk treatment strategy that attempts to eliminate or reduce any remaining uncontrolled risk through the application of additional controls and safeguards in an effort to change the likelihood of a successful attack on an information asset; also known as the defense strategy.

The company now has a list of information assets with unacceptable levels of risk.

- The appropriate strategy must be selected and applied.

Four basic strategies to treat risk:

1) Mitigation: Apply safeguards that eliminate or reduce the remaining uncontrolled risk.
   - Example: Firewall, Training, …
2) Transfer: Shift risks to other areas or outside entities.
   - Example: Outsourcing
3) Acceptance: Understand the consequences of choosing to leave an information assets vulnerability facing the current risk level (after formal evaluation).
4) Termination: Remove or discontinue the asset from the organization's operating environment.

5.12.8.1. Mitigation

- Fix vulnerabilities
- Applying controls (tools, processes, rules to mitigate risk)
  - Endpoint Hardening (preventive Control): Secure a "endpoint" (device: laptop, server, …) by reducing its vulnerabilities and shut down potential threat vectors!
- Reduce final impact (If zero-day attacks, unknown vulnerabilities, or a taken risk happen)
  - EDR (Endpoint Detection and Response): Software that watches for suspicious behaviour and responds with certain measures.
  - XDR (Extended Detection and Response): Watching everywhere (not just on endpoints) and respond with certain measures (shut down infected laptop, …)

5.12.9. Other RM Frameworks

- OCTAVE (Operationally Critical Threat, Asset and Vulnerability Evaluation) by the Carnegie Mellon University.
- FAIR (Factor Analysis of Information Risk) by Jack A. Jones.
- ISO Standards: ISO 27005 and ISO 31000: (explanation: https://en.wikipedia.org/wiki/ISO/IEC_27005).

– NIST Risk Management Framework (RMF): https://csrc.nist.gov/publications/sp